Queen Mira International School

QMIS ERP

Complete Login, Role, Permission & Workflow Audit

Document date: 22 October 2026

Verification-only audit — source inspection + safe login probes

Passwords, tokens, and secrets omitted

Verification-only audit; application code and database were not modified.

Table of Contents

1. Executive Summary
2. Login Pages Inventory
3. Transport Driver Login Verification
4. Complete Role Catalog
5. Role-versus-Module Access Matrix
6. Authentication & Authorization Flow
7. Role-Specific Workflows
8. Frontend / Backend Consistency Findings
9. Missing Features & Security Risks
10. Recommendations (P0 / P1 / P2)
11. Evidence Index

Appendix A–C

1. Executive Summary

QMIS ERP uses a single shared login at **/signin** for all personas. There is no separate Transport Driver login URL. After JWT authentication, App.jsx routes users into role portals by URL prefix. Backend authorization uses a role→permission matrix; menu visibility alone is not security.

1.1 Headline findings

- Shared login only: /signin (+ /select-profile helper, /signup stub).
- **Transport Driver:** portal /driver/* and ops permissions exist; dedicated login page missing; **no seeded driver User** — API probes returned invalid_credentials for driver@qmis.edu and driver@school.com.
- Hostel Warden is not a system role. Admissions Officer is not a role (use PRM).
- 10 development seed users (@qmis.edu). Many portals lack seed logins (librarian, TM, driver, auditors, stores).
- managing_director exists in BE only. finance_assistant shares Account Head UI with reduced finance rights.

1.2 Status snapshot

Area	Status	Notes
Shared /signin	Implemented	SignIn.jsx
JWT + bcrypt	Implemented	POST /auth/login
Role portals	Implemented	App.jsx prefixes
Permission matrix	Implemented	matrix.py
Driver portal UI	Implemented	DriverRoutes.jsx
Driver login identity	Missing/Partial	No seed user
Dedicated driver login page	Missing	Shared SignIn by design
Hostel Warden role	Missing	Not in ROLES
OTP FE login	Unverified	API present

2. Login Pages Inventory

URL	Purpose	Status
/signin	Primary login all roles	Implemented
/select-profile	Role picker → /signin	Implemented
/signup	Empty shell	Missing stub
/change-password	Forced password change	Implemented

Persona	Dedicated login?	Portal
Super Admin / Admin / Director / Principal	No — /signin	/super-admin, /admin, /director, /principal
Teacher / Coordinator / HR	No — /signin	/teacher, /coordinator, /hr
Student / Parent	No — /signin	/student, /parent
Transport Manager	No — /signin	/transport-manager
Transport Driver	No — /signin	/driver
Account Head / Finance Assistant	No — /signin	/account-head
PRM (Admissions)	No — /signin	/front-office
Librarian	No — /signin	/librarian
Hostel Warden	N/A	No role

3. Transport Driver Login Verification

Verdict: Partially Implemented. Drivers are expected to use the shared /signin page. The driver portal and backend ops permissions are implemented, but no driver authentication identity is seeded, so end-to-end driver login cannot be

verified as working.

Check	Result
Dedicated driver login page	Missing
Driver FE routes /DriverLayout	Implemented
ROLES.DRIVER + BE role	Implemented
ops.read / ops.write for driver	Implemented
Seeded driver credentials	Missing
DEMO chip for driver	Missing
API login driver@qmis.edu	Failed — invalid_credentials
API login driver@school.com	Failed — invalid_credentials
Shared staff login usable if User exists	Yes (design)

Transport workflow step	Status
TM manages vehicles/routes/drivers	Implemented (UI+ops); TM seed missing
Assign students	Implemented (UI)
Driver login	Missing identity
Driver view route / mark attendance	Partial (pages exist)
TM monitors operations	Implemented (UI)

4. Complete Role Catalog

Frontend defines 27 role codes in src/constants/roles.js. Backend ALL_ROLES = 25 frontend roles + managing_director + finance_assistant.

Seeded demo users (dev)	Role
superadmin@qmis.edu	superadmin
admin@qmis.edu	admin
director@qmis.edu	director
principal@qmis.edu	principal
coordinator@qmis.edu	coordinator
teacher@qmis.edu	teacher
prm@qmis.edu	prm
hr@qmis.edu	hr
accounthead@qmis.edu	accounthead
finance.assistant@qmis.edu	finance_assistant

Not seeded: driver, transportmanager, librarian, student, parent, gatekeepers, JD roles, auditors, store/canteen/IT/HK managers.

5. Role-versus-Module Access Matrix

Enforcement: FE menu (sidebarLinks.js) ≠ FE route prefix (App.jsx) ≠ BE permissions (matrix.py) ≠ campus_id isolation. Authoritative mutations require BE permission checks.

Module	Full admin	Principal	Teacher	HR	Acct Head	Fin Asst	PRM	TM	Driver	Parent
Users/RBAC	VCED	—	—	—	—	—	—	—	—	—
Admissions	VCE	—	—	—	—	—	VCE	—	—	—
Students	VCE	VCE*	V	V	V	V	V	V	—	own
Attendance	VCE	VCE	VCE	—	—	—	—	—	—	V
Finance	Full	—	—	—	Full	Collect	—	—	—	Pay V

Module	Full admin	Principal	Teacher	HR	Acct Head	Fin Asst	PRM	TM	Driver	Parent
HR/Payroll	Full	—	—	Full	—	—	R emp	—	—	—
Leave	VCEA	VCEA	VC	VCEA	VC	VC	VC	VCEA	VC	—
Transport	ops	ops	ops	ops	ops R	—	—	VCE	VCE	V
Announcements	VCE	VCE	V	VCE	V	V	V	V	V	V

V=View C=Create E=Edit D=Delete A=Approve. Full roles also include managing_director. See matrix.py for exact codes.

6. Authentication & Authorization Flow

1) /signin → 2) AuthContext → 3) POST /api/v1/auth/login → 4) bcrypt + lockout → 5) JWT HS256 → 6) store token/session → 7) optional /change-password → 8) ROLE_HOME_PATHS → 9) Bearer APIs → 10) get_current_user + require_permission / ops ACL → 11) logout clears client token (JWT stateless until expiry).

Control	Status
Password hashing (bcrypt)	Implemented
must_change_password gate	Implemented
Token refresh	Missing / Unverified
Self-service password reset	Unverified / likely incomplete
Campus isolation (campus_id)	Implemented (single seed campus)
Parent/student provisioning on enroll	Implemented
Offline demo login	Dev-only flag

```
[SignIn]→[AuthContext]→[POST /auth/login]→[JWT]→[Home by role]→[Bearer APIs]→[require_permission]
```

7. Role-Specific Workflows (summary)

Role	Home	Status
Super Admin / Admin	/super-admin/* · /admin/*	Implemented (seeded)
Director / Principal / Coord / Teacher	role dashboards	Implemented (seeded)
HR / Account Head / Fin Asst / PRM	role dashboards	Implemented (seeded)
Parent / Student	/parent · /student	Partial (enroll/offline)
Librarian / TM / Driver / Auditors / Stores	role portals	Partial (UI; no seed login)

Transport: TM manages fleet → assign drivers/students → driver uses shared /signin (identity Missing) → /driver portal (Implemented) → attendance/route (Partial) → TM monitors (Implemented).

8. Frontend / Backend Consistency

Finding	Severity
@school.com vs @qmis.edu email mismatch	P1
managing_director without FE portal	P1
Driver/TM/Librarian unseeded	P0 demo
DEMO passwords in FE source	P0 security
Stateless logout (JWT still valid)	P1
Driver sidebar/home mismatches	P2
/signup stub	P2

9. Missing Features & Security Risks

Item	Notes
Driver login identity	Portal ready; User missing
Forgot password	Control present; full flow Unverified
No refresh tokens	TTL-dependent risk
Export auth	Often UI-only — Unverified BE
Hostel Warden	Not modeled as role

10. Recommendations

P0

- Seed or create driver + transportmanager Users for UAT.
- Remove demo passwords from production client bundles.
- Implement or remove Forgot Password to avoid false assurance.

P1

- Align offline emails with API seeds; map or drop managing_director FE gap.
- Document shared /signin for drivers; add non-prod demo chip after seeding.
- Short JWT TTL and/or denylist for logout integrity; seed librarian/auditors if in demo scope.

P2

- Align driver sidebar with routes; fix home path; finish or remove /signup.
- Add Hostel Warden only if product requires it; FE permission-aware menus; export BE checks.

11. Evidence Index

Artifact	Path
FE roles	src/constants/roles.js
Auth / home paths	src/context/AuthContext.jsx
Routing gate	src/App.jsx
Sign-in	src/Pages/Authentication/SignIn.jsx
Sidebars	src/Common/CommonSidebar/Components/sidebarLinks.js
Driver routes	src/Routes/DriverRoutes.jsx
Permission matrix	backend/app/permissions/matrix.py
Auth API	backend/app/api/v1/endpoints/auth.py
Seed users	backend/app/services/seed.py
JWT security	backend/app/core/security.py

Appendix A — Mermaid (source)

```
sequenceDiagram: User→SignIn→POST /auth/login→JWT→Home by role→Bearer APIs→require_permission
```

```
flowchart: TM→Vehicles/Routes→Assign Drivers/Students-.->Driver /signin→/driver portal→Attendance→TM monitor
```

Appendix B — Auth endpoints

Method	Path
POST	/api/v1/auth/login
POST	/api/v1/auth/otp/challenge

Method	Path
POST	/api/v1/auth/otp/verify
POST	/api/v1/auth/change-password
POST	/api/v1/auth/logout
GET	/api/v1/auth/me

Appendix C — Login probes

Account	Result
accounthead@qmis.edu	OK — seed path verified
driver@qmis.edu	invalid_credentials
driver@school.com	invalid_credentials

Final status

Transport Drivers do not have a separate working login page. They share /signin. Driver portal UI and backend ops permissions are implemented, but without a provisioned driver User the login is not end-to-end usable. Verified seeded roles for demo: Super Admin, Admin, Director, Principal, Coordinator, Teacher, PRM, HR, Account Head, Finance Assistant.

Verification-only audit; application code and database were not modified.